ช่วง 6 · เช็กกันพลาด 15 นาที

ก่อนปิดคาบ

ไล่เช็กทีละข้อ แล้วเปิดไฟล์เต็มเทียบถ้ามีข้อไหนไม่ผ่าน

- ✓ ไม่มีคำว่า `auth.loggedIn` / `toggleLogin` / ปุ่ม 🧪 เหลือในโปรเจกต์
- ✓ ไม่ล็อกอิน → เข้า /admin ไม่ได้ · ล็อกอินแล้ว F5 ไม่หลุด
- ✓ ไม่ล็อกอิน → ฐานข้อมูลปฏิเสธการเพิ่ม (ด่าน RLS)
- ✓ ปิด "Allow new users to sign up" แล้ว
- ✓ แก้ราคา/ลบสินค้าได้ มีถามยืนยันก่อนลบ
- ✓ ข้อความที่ผู้ใช้พิมพ์แสดงด้วย `{{ }}` ไม่มี v-html
- ✓ บันทึกผลทดสอบผู้ใช้ครั้งที่ 1 ในใบงานแล้ว

▸ ✅ **ไฟล์เต็ม ณ จุดนี้ (จบสัปดาห์ 13)** (ยังไม่รวมลองเอง)

> 🔭 **ปูทางสัปดาห์หน้า**
>
> สัปดาห์ 14: จัดระเบียบ store ด้วย **Pinia** แล้ว **นำเว็บขึ้นออนไลน์ (Deploy)** ได้ลิงก์จริงเปิดจากมือถือ + **วางแผนลงพื้นที่** (4 คาบนอกเวลาเรียน) — เริ่มติดต่อชุมชน/ผู้ใช้ที่จะไปเยี่ยมไว้เลย

ภาค B · ใบงานส่งท้ายคาบ

ใบงานทีม ≈ 2–3 ชม. (ทำต่อนอกคาบได้)

ใบงาน 12 — CRUD + ล็อกอิน + ความปลอดภัย + ทดสอบผู้ใช้ครั้งที่ 1

ทำเป็นทีม ต่อยอดแอปของทีม: ทำ CRUD ให้ครบกับตารางหลัก ล็อกหลังบ้านด้วย Supabase Auth ตั้ง RLS ให้เขียนได้เฉพาะผู้ดูแล กัน XSS และบันทึกผลทดสอบกับผู้ใช้จริงครั้งที่ 1

> 🔐 **ถ้าแอปทีมมีข้อมูลส่วนบุคคล**
>
> เช่น ชื่อ เบอร์โทร ที่อยู่ อาการป่วย — กฎ SELECT ต้องเป็น `to authenticated` (ผู้ดูแลเท่านั้น) ไม่ใช่ anon · ถ้าผู้ใช้ทั่วไปต้องส่งข้อมูลโดยไม่ล็อกอิน ให้มีแค่กฎ INSERT สำหรับ anon (ส่งได้แต่อ่านของคนอื่นไม่ได้)

ข้อมูลทีม

ชื่อทีม / ชื่อโปรเจกต์

น้ำ แข็งใส

กลุ่มเรียน (Section)

DT36921N

สมาชิกในทีม (ชื่อ–สกุล + รหัสนักศึกษา)

014 ธนพร กาฬภักดี
015 ธนภัทร ฐิติวิวัฒน์
024 มนต์ธการต์ ศรีชลวงศ์

ส่วนที่ 1 · ออกแบบสิทธิ์

ประมาณ 20 นาที

ใครทำอะไรกับตารางหลักได้บ้าง (ตอบเป็นตาราง บทบาท × อ่าน/เพิ่ม/แก้/ลบ)

ผู้ใช้งานทั่วไป (anon): อ่าน ✓ · เพิ่ม X · แก้ X · ลบ X
ผู้ดูแลระบบ (authenticated): อ่าน ✓ · เพิ่ม ✓ · แก้ ✓ · ลบ ✓

ซ่อนเมนูแล้ว ทำไมยังต้องมี guard และ RLS (อธิบาย 3 ด่านด้วยคำของทีม)

ยังไม่ได้เข้าสู่ระบบ
3. ด่านฐานข้อมูล (RLS - Row Level Security): เป็นปราการด่านสุดท้ายที่ระดับ Supabase คอยตรวจสอบสิทธิ์ ถ้าไม่มี token หรือไม่ได้ล็อกอินเป็น authenticated จะ

ส่วนที่ 2 · วางโค้ดจริงของทีม

ประมาณ 90 นาที

วาง SQL กฎ RLS ทิงหมดของตารางหลัก

```
with check (true);

create policy "logged in can delete"
on public.medication_reminders for delete
to authenticated
using (true);
```

วางโค้ดฟังก์ชัน update + delete (ต้องมี .eq() และเช็ก data.length)

```
  if (error) return error.message;
  if (data.length === 0) return 'ไม่มีสิทธิ์ลบ (ยังไม่ได้ล็อกอิน?) หรือไม่พบรายการยา';
  await loadMedications();
  return '';
}
```

วางโค้ด router guard + ฟังก์ชัน signIn

```
  // ถ้าหน้าที่กำลังจะไปต้องใช้สิทธิ์แอดมิน (meta.requiresAuth) แต่ยังไม่ได้ล็อกอิน
  if (to.meta.requiresAuth && !user.value) {
    next('/login'); // ดีดไปหน้าล็อกอิน
  } else {
    next(); // ไปต่อได้ปกติ
  }
});
```

ส่วนที่ 3 · เกณฑ์ให้คะแนน (ติ๊กให้ครบก่อนส่ง)

รวม 100 คะแนน

- [ ] **ล็อกอิน/ออก ด้วย Supabase Auth + เมนูเปลี่ยนตามสถานะ** — 15
  สร้างบัญชีผู้ดูแลจากหลังบ้าน · ปิดการสมัครเอง
- [ ] **Route guard ผูกผู้ใช้จริง (รอ authReady)** — 10
  F5 ที่หน้าหลังบ้านไม่หลุด
- [ ] **RLS: เขียนได้เฉพาะผู้ดูแล · ข้อมูลส่วนตัวไม่เปิดให้ anon อ่าน** — 20
  ลบกฎ TEMP แล้ว · พิสูจน์ด้วยการทดสอบตอนไม่ล็อกอิน

- [ ] **Update ทำงาน มี .eq() + เช็กผลแบบ RLS เงียบ** 15
  .select() + data.length
- [ ] **Delete ทำงาน มีถามยืนยัน** 10
  confirm ก่อนลบ
- [ ] **กัน XSS: ไม่มี v-html กับข้อมูลผู้ใช้ + ไม่มี secret key ในโค้ด** 10
  ทดสอบด้วยชื่อ <img ...>
- [ ] **ทดสอบผู้ใช้จริงครั้งที่ 1 + แก้ปัญหาที่พบ ≥ 1 จุด** 15
  บันทึกครบในส่วนที่ 4
- [ ] **คอมเมนต์ + ส่งงานถูกต้อง** 5
  ลบ node_modules · ไม่แนบ .env.local · ไม่เขียนรหัสผ่านไว้ในงาน

ส่วนที่ 4 · ผลทดสอบกับผู้ใช้จริง ครั้งที่ 1

ช่วง 5 ของคาบ

ผู้ทดสอบ (บทบาท/ช่วงอายุ — ไม่ต้องใส่ชื่อจริง · ระบุถ้าเป็นผู้ทดสอบจำลอง)

เช่น ผู้สูงอายุหญิง อายุ 60–70 ปี ใช้มือถือ Android ของตัวเอง

งานที่ให้ทำ (ประโยคที่อ่านให้ผู้ใช้ฟัง)

เช่น "ลองสั่งผ้าทอมือ 1 ผืน แล้วดูว่าต้องจ่ายเท่าไร"

ผลการสังเกต (สำเร็จไหม · กี่นาที · ติดตรงไหน · คะแนนความง่าย 1–5)

เช่น สำเร็จ ใช้ 4 นาที · หาปุ่มตะกร้าไม่เจอ (อยู่มุมบน ตัวเล็ก) · ให้ 3/5

คำพูดจริงของผู้ใช้ 1–2 ประโยค

เช่น "ตัวหนังสือเล็กไปหน่อยนะ ยายต้องหยิบแว่น"

สิ่งที่ทีมแก้แล้ว (ก่อน → หลัง) (อย่างน้อย 1 จุด)

เช่น ปุ่มตะกร้า: ตัวอักษร 14px มุมขวาบน → 20px + ไอคอน + คำว่า "ตะกร้า"

ส่วนที่ 5 · ภาพหลักฐาน

- [ ] **cp01-login-error.png + cp02-admin-f5.png**
  หน้า login รหัสผิด · /admin หลัง F5 (ช่วง 1)
- [ ] **cp03-rls.png**
  ฐานข้อมูลปฏิเสธตอนไม่ล็อกอิน (ช่วง 2)
- [ ] **cp04-crud.png**
  แก้ราคาสำเร็จในตารางหลังบ้าน (ช่วง 3)
- [ ] **cp05-xss.png**
  ชื่อ <img ...> แสดงเป็นตัวอักษร (ช่วง 4)
- [ ] **cp06-usertest.jpg**
  ภาพทดสอบผู้ใช้ (เฉพาะที่ยินยอม)
- [ ] **cp-try1 / cp-try2 / cp-try3.png**
  ลองเองทั้งสามจุด
- [ ] **ws01-policies.png + ws02-crud.png**
  แอปทีม: หน้า Policies ของตารางหลัก · หน้าหลังบ้านที่แก้/ลบได้

ส่วนที่ 6 · สะท้อนการเรียนรู้

บั๊ก/ปัญหาที่เจอ และวิธีแก้ (อย่างน้อย 2 เรื่อง)

เช่น แก้ราคาแล้วไม่มี error แต่ไม่เปลี่ยน เพราะไม่มี policy update — RLS ปฏิเสธแบบเงียบ

สิ่งที่เข้าใจชัดขึ้น และอยากศึกษาต่อ

วิธีส่งงาน

1. **ลบ** `node_modules` · ตรวจว่า `.env.local` **ไม่ติดไป** · ไม่มีรหัสผ่านผู้ดูแลในไฟล์ใด
2. zip ตั้งชื่อ `ใบงาน12_ชื่อทีม.zip`
3. กด "บันทึกเป็น PDF" หรือ "บันทึกเป็น Word"
4. แนบภาพหลักฐานตามส่วนที่ 5
5. ส่งบัญชีผู้ดูแลสำหรับตรวจงาน **ให้อาจารย์ทางช่องทางส่วนตัว** (ไม่ใส่ในใบงาน)

💡 **ปุ่ม PDF** เปิดหน้าต่างพิมพ์ → ช่อง "ปลายทาง/Destination" เลือก **"บันทึกเป็น PDF"** (หรือกด `Ctrl` / `Cmd` + `P`) · ถ้ากดแล้วไม่มีอะไรขึ้น ให้ **ดาวน์โหลดไฟล์นี้ไปเปิดในเบราว์เซอร์ก่อน**

คำตอบจะถูกบันทึกอัตโนมัติในเครื่องนี้ขณะพิมพ์ เปิดไฟล์ใหม่ก็ยังอยู่ (เฉพาะเบราว์เซอร์เดิม)